

# Test case progress

*Going through the catalog I put together for the three lanes I'm targeting — detection & response, IAM, cloud security. This is where I'm actually keeping track of what's real versus what's still a plan, since it's easy to lose track once there are 25+ of these.*

## Where things stand, roughly

| Category                 | Actually built and working                | Real but incomplete                              | Not started (and why)                                               |
|--------------------------|-------------------------------------------|--------------------------------------------------|---------------------------------------------------------------------|
| 1. Detection engineering | all 8 rules, converted to KQL             | —                                                | —                                                                   |
| 2. Atomic Red Team       | —                                         | —                                                | all 4, waiting on the Windows VM I haven't built                    |
| 3. SOAR                  | infra only (TheHive+Cortex up and linked) | —                                                | all 4, need a custom Cortex analyzer written                        |
| 4. IAM                   | 2 of 5 (the Graph scripts)                | —                                                | 3 of 5, need the free M365 dev tenant signup                        |
| 5. Cloud security        | 2 of 5                                    | 1 of 5 (privesc query, no live log to run it on) | 2 of 5, need Defender for Cloud/Azure Policy on a real subscription |
| 6. AI-assisted           | both scripts, not run live yet            | —                                                | —                                                                   |

## 1. Detection engineering — all 8 done

---

| #   | Rule                         | Where it points                         |
|-----|------------------------------|-----------------------------------------|
| 1.1 | Impossible travel            | SigninLogs                              |
| 1.2 | Password spray               | SigninLogs + hand-written aggregation   |
| 1.3 | Suspicious OAuth consent     | AuditLogs                               |
| 1.4 | Privileged role assignment   | AuditLogs                               |
| 1.5 | Mass file download           | OfficeActivity                          |
| 1.6 | Conditional Access tampering | AuditLogs                               |
| 1.7 | Anomalous PowerShell         | imProcessCreate (Defender for Endpoint) |

What's real here: all 8 convert cleanly, all 8 are syntactically valid. What's not real yet: none of them have run against actual sign-in data from a real tenant, so I genuinely don't know their false-positive rate. "Converts" and "works" aren't the same claim and I'm not going to pretend they are just because the list is complete.

## 2. Atomic Red Team — nothing run yet

---

2.1 through 2.4 all need the same thing: an isolated Windows VM in UTM, which I haven't built. Not a cost issue, not a skill issue — it's a several-GB download with a Microsoft EULA attached and I'd rather actually build it deliberately than have it appear for me. The safety rules for when I do (VM only, NAT networking, snapshot before every run) are already written down in the repo. Rules 1.1/1.2, 1.4, and 1.7 above are already sitting there waiting to be validated once I have telemetry to test them against.

### 3. SOAR — infra's up, automation isn't built

---

TheHive and Cortex are both running and linked to each other — that part's genuinely done. What's missing for 3.1 through 3.3 is a custom Cortex analyzer, which means writing an actual Python class against Cortex's analyzer SDK ( `cortexutils` ). That's real, scoped development work, not something to fake with a placeholder script. 3.4 (ticket creation) is arguably done by definition — a TheHive case already is the ticket, there's no separate system to bolt on.

Next concrete step: build one analyzer against something I already have live data for — take a username observable, query LocalStack's IAM for what that account can actually do. That's a real target, not a hypothetical one, since LocalStack's already running.

## 4. IAM — 2 done, 3 waiting on a free tenant signup

---

| #   | Item                      | Needs a paid license?                                                       |
|-----|---------------------------|-----------------------------------------------------------------------------|
| 4.1 | Access review script      | No — done, Graph API is free on any tier                                    |
| 4.2 | Orphaned account script   | No — done, same reason                                                      |
| 4.3 | Conditional Access matrix | Needs P1 — not started                                                      |
| 4.4 | PIM walkthrough           | Needs P2 — not started                                                      |
| 4.5 | RBAC audit                | No — just needs a subscription with real assignments to review, not started |

The thing worth knowing about 4.3 and 4.4: the Microsoft 365 Developer Program gives a free sandbox tenant with a 90-day E5 trial, which includes both Conditional Access and PIM. So this isn't actually a money problem, it's just three things I haven't gotten around to yet.

## 5. Cloud security — mixed

---

| #   | Item                           | Status                                                                                                                                                                  |
|-----|--------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 5.1 | Misconfig then fix             | Terraform real, applied. The Defender for Cloud finding is documented rather than screenshotted — didn't want to actually expose SSH to the internet just for a picture |
| 5.2 | Public storage lockdown        | not started, needs a configured subscription                                                                                                                            |
| 5.3 | Key Vault access review        | not started                                                                                                                                                             |
| 5.4 | Azure Policy dashboard         | not started                                                                                                                                                             |
| 5.5 | AWS IAM privesc via CloudTrail | attack sim real (LocalStack), detection query written against real CloudTrail schema, never actually fired against live output                                          |

On 5.5 specifically: I could've made up a fake CloudTrail log and run my query against it to get a green checkmark, and decided not to — that only proves I can write SQL that matches data I invented to match it. Left it as an honest gap instead. Full writeup's in the [aws-identity-detection](#) repo.

## 6. AI-assisted — both scripts written

---

The alert summarizer and the incident timeline builder both install cleanly and I've checked the SDK calls are shaped correctly, but I haven't actually run either one against a live API key yet — so "produces a genuinely useful summary" is still something I need to go confirm myself. Worth noting this is the one category where "free" doesn't apply the same way as everything else — API calls cost a small amount per token, unlike Wazuh/TheHive/LocalStack/Terraform which are all actually zero-cost.

## What I'm actually doing next, in order

---

1. Sign up for the Microsoft 365 Developer Program sandbox — unblocks 4.3, 4.4, and gives me a real tenant to finally test the Category 1 rules against
2. Build the Windows VM in UTM, run 2.1 through 2.3 against the rules already written
3. Write one real Cortex analyzer against LocalStack IAM data — closes the loop on 3.1
4. Open a real AWS free-tier account, turn on CloudTrail, actually run the 5.5 query for once

Not trying to do all of these at once. One or two a week is realistic; trying to do more than that is how projects like this end up half-finished in six directions instead of finished in one.